Plan: administrar usuarios administradores

Estado: Completado y verificado localmente (2026-10-02) · **Progreso:** 6/6 checkpoints

Este plan agrega una interfaz para que los administradores gestionen otras cuentas admin sin mezclar esa tarea con **Cuentas Técnicas**. El archivo es el registro de avance: marcar cada checkpoint solo cuando sus criterios estén verificados.

La implementación está en la rama actual. Su verificación es local; no implica que exista un ambiente AWS desplegado (staging fue eliminado y producción no está desplegada).

Decisión de diseño

- Crear una vista administrativa independiente, enlazada desde la navegación existente y protegida por `users:manage`.
- Mantener **Cuentas Técnicas** enfocada en técnicos y en la designación de la cuenta compartida.
- Mostrar únicamente usuarios `ADMIN`; crear admins con el rol fijo `ADMIN`, sin selector de roles.
- Reutilizar las rutas actuales `GET/POST/PATCH /api/v1/users` si la verificación de permisos y reglas de dominio confirma que cubren los casos. No agregar un modelo ni una migración Prisma salvo que aparezca un requisito que realmente lo necesite.
- Usar una tabla compacta con búsqueda/estado y acciones por fila. Crear, editar y cambiar contraseña se resuelven en modales, no en formularios permanentes que carguen la vista.

Alcance

Incluye: listar admins; crear una cuenta admin; editar nombre/correo; restablecer contraseña; activar o desactivar; autorización de API y ruta; pruebas y documentación.

No incluye: gestión de técnicos, designación de cuenta compartida, cambios de credenciales de AWS/Google, cambios al flujo de login ni políticas de invitación o recuperación por correo.

Checkpoints

C0 · Confirmar el estado actual — completado

- [x] Confirmado que el endpoint y el servicio de usuarios ya existen; la interfaz actual filtra `TECHNICIAN` y fija ese rol al crear.
- [x] Confirmado que el panel de cuenta compartida y las cuentas técnicas deben seguir separados de la administración de admins.

- ☑ No se modificó código de la funcionalidad.

C1 · Cerrar reglas de dominio y autorización

- ☑ Confirmado que `GET/POST/PATCH /api/v1/users` exige `users:manage` en servidor; la protección visual de la ruta no sustituye esta autorización.
- ☑ Creación fija con rol `ADMIN`; cambio de contraseña pasa por la política mínima vigente de 12 caracteres.
- ☑ Se bloquea el auto-bloqueo y la desactivación/degradación del último admin activo; las actualizaciones usan transacción serializable.
- ☑ Se preservan la cuenta técnica compartida, la auditoría y la revocación de sesiones existentes.

Criterio de salida: las reglas críticas tienen pruebas, y una llamada no autorizada no puede listar, crear ni modificar admins.

C2 · Agregar una entrada administrativa protegida

- ☑ Crear ruta `/admin/users`, protegida con `requiresRole: 'ADMIN'` (rol que posee `users:manage`).
- ☑ Mostrar la entrada de navegación solo a admins, en escritorio y móvil.
- ☑ Guard de ruta deniega el acceso directo a usuarios sin permiso; API también deniega listados y cambios.
- ☑ Se mantiene **Cuentas Técnicas** separada y sin cambios funcionales.

Criterio de salida: un admin llega a la vista desde navegación; un técnico es redirigido y además recibe rechazo de API si intenta llamar el endpoint.

C3 · Implementar la vista de admins sin sobrecargar otras pantallas

- ☑ Se agrega `modules/admin-users` para vista y operaciones; las operaciones genéricas se comparten desde `modules/user-management`.
- ☑ La lista se filtra a admins y ofrece búsqueda por nombre/correo y estado.
- ☑ Creación siempre fija `ADMIN`; edición, cambio de contraseña y estado están disponibles por fila.
- ☑ Formularios modales con estados de carga/error/vacío y confirmación antes de desactivar.
- ☑ Contraseñas nunca se vuelven a mostrar; campos sensibles se limpian al cerrar modal.
- ☑ Vista responsiva con navegación móvil, labels/aria-labels y tabla desplazable en pantallas angostas.

Criterio de salida: la pantalla tiene una tarea clara, no duplica la configuración de cuenta compartida y no expone acciones de técnicos.

C4 · Cubrir comportamiento y seguridad con pruebas

- [x] Pruebas del módulo verifican filtrado a `ADMIN` y rol fijo de creación; pruebas existentes validan API de cuentas técnicas.
- [x] Pruebas de router verifican denegación a técnicos; pruebas de API verifican denegación para GET/POST/PATCH.
- [x] Pruebas de servicio cubren último admin y auto-bloqueo; reglas existentes de cuenta compartida permanecen.
- [x] Pruebas de `TechnicalAccountsView` /API continúan pasando.

Criterio de salida: las pruebas enfocadas cubren las operaciones y los casos de acceso/regresión.

C5 · Documentar operación y soporte

- [x] `docs/technical/api.md` documenta permisos, semántica y códigos de error.
- [x] `MANUAL_USUARIO.md` documenta el ciclo de gestión de admins y contraseña segura.
- [x] `docs/technical/security-and-quality.md` documenta límites, auditoría y concurrencia.
- [x] No se documentan credenciales reales ni secretos.

Criterio de salida: una persona administradora puede completar el flujo siguiendo la documentación sin depender de credenciales compartidas en texto.

C6 · Verificación final y cierre

- [x] `pnpm --filter @puk/api test` y `pnpm --filter @puk/web test` aprobados.
- [x] `pnpm typecheck`, `pnpm lint` y `pnpm test` aprobados.
- [x] `git diff --check` aprobado; no se cambió el modelo ni las migraciones Prisma; suite de cuentas técnicas aprobada.
- [x] Plan marcado como completado; no hubo desviaciones de alcance.

Criterio de salida: comandos aprobados, documentación sincronizada y todos los checkpoints previos marcados.

Archivos previstos

La lista se confirma durante la implementación; no implica que estos cambios ya existan.

- `apps/web/src/modules/admin-users/` — nueva vista, componentes, API y pruebas de admins.
- `apps/web/src/router/` y navegación de `AppLayout` — ruta protegida y entrada visible por capacidad.
- `apps/api/src/modules/users/` y sus pruebas — reglas de dominio que falten; conservar endpoints actuales cuando sea posible.
- `apps/api/src/modules/administration/administration.router.test.ts` — verificar permisos/contratos existentes.

- `docs/technical/api.md` y guía de usuario existente — documentación según los cambios efectivos.

Registro de cambios del plan

- 2026-09-30 — Plan creado tras verificar que la UI gestiona cuentas técnicas, mientras el backend ya ofrece endpoints genéricos protegidos para usuarios.
- 2026-09-30 — Implementados los checkpoints C1-C6: controles para evitar auto-bloqueo/último admin, módulo y ruta separados, pruebas y documentación; sin migraciones Prisma.